SRS · TechnoStore: Tienda en línea con dinero digital simulado

Aprendices:

Danna Michelle Farfan Ramírez

Cristian Camilo Alegria Rivera

Kevin Camilo Caballero Oliveros

Deiner Smit Limas Lavao

Juan Manuel Silva Castañeda

Programa: Análisis y Desarrollo de Software (ADSO) - Ficha 3407799

Centro de Formación: Centro de la Industria, la Empresa y los Servicios (SENA)

Fecha: 09/2026

1. Introducción

1.1 Propósito

TechnoStore busca que una tienda de tecnología pueda vender sus productos en línea desde un canal propio, sin depender de plataformas de terceros. El sistema reúne en una sola aplicación el catálogo, la búsqueda, el carrito, el pago, el seguimiento de pedidos y un panel administrativo para gestionar productos, stock, pedidos, usuarios, la apariencia de la tienda y reportes en Excel.

El proyecto también tiene un propósito formativo: demostrar la construcción de una aplicación web completa con base de datos relacional, procedimientos almacenados, transacciones que protegen el inventario y el saldo, control de acceso por roles y generación de documentos. El módulo de dinero digital es un saldo simulado que permite estudiar esa consistencia de datos sin manejar dinero real, por lo que sus comprobantes no tienen validez fiscal.

1.2 Alcance

El sistema incluye: catálogo público y búsqueda; registro e inicio de sesión; carrito y confirmación de pedidos; pago con dinero digital (saldo, recargas, movimientos y comprobantes virtuales); seguimiento y cancelación de pedidos; panel de administración (productos, categorías, stock, pedidos, usuarios, personalización y reportes en Excel); y notificaciones por correo electrónico de los cambios de estado de un pedido.

El sistema no incluye: integración real con pasarelas de pago (tarjeta, PSE o Nequi), facturación electrónica ante la DIAN, integración con transportadoras, ni retiro, transferencia o reembolso en dinero del saldo digital. El dinero digital es un saldo simulado sin valor monetario real.

1.3 Definiciones, acrónimos y abreviaturas

- **Visitante:** persona sin sesión iniciada que navega la tienda.
- **Cliente:** usuario registrado con rol CLIENTE.
- **Administrador:** usuario con rol ADMINISTRADOR.
- **Carrito:** pedido en estado CARRITO asociado a un cliente. Cada usuario tiene como máximo un carrito activo.
- **Dinero digital:** saldo simulado asociado a cada usuario, con el que se pagan pedidos dentro de la tienda.
- **Comprobante:** documento virtual numerado (formato COMP-000001) que respalda un pago con dinero digital. No tiene validez fiscal.
- **Movimiento:** registro de una recarga, un pago o un reembolso sobre el saldo digital.
- **Baja lógica:** desactivación de un registro mediante una marca (activo = falso) sin borrarlo de la base de datos.
- **HU:** historia de usuario.
- **RF:** requerimiento funcional.
- **RNF:** requerimiento no funcional.
- **RN:** regla de negocio.
- **COP:** peso colombiano, moneda única del sistema.
- **API:** interfaz de programación del backend (archivo api.php), que responde en formato JSON.

- **PDO:** PHP Data Objects, capa de acceso a la base de datos usada por el sistema.
- **SMTP:** protocolo de envío de correo electrónico.
- **Ley 1581 de 2012:** régimen colombiano de protección de datos personales (habeas data).
- **Ley 1480 de 2011:** Estatuto del Consumidor colombiano.

1.4 Referencias

- Código fuente del proyecto: api.php, index.php, reporte.php, xlsx.php, mailer.php y config.php.
- Script de base de datos bdcatalogo.sql (base de datos catalogo_ecommerce).
- Parches dinero-digital.patch y frontend-dinero-digital.patch, que agregan el módulo de dinero digital.
- Ley 1581 de 2012 (protección de datos personales) y Ley 1480 de 2011 (Estatuto del Consumidor).
- Términos y Condiciones publicados en la tienda (última actualización: noviembre de 2026).

1.5 Visión general del documento

La sección 2 describe el producto, sus usuarios y sus restricciones. La sección 3 presenta las historias de usuario agrupadas por épica. La sección 4 define los requerimientos funcionales por módulo. La sección 5 contiene los requerimientos no funcionales. La sección 6 describe el modelo de datos, la sección 7 las reglas de negocio y la sección 8 las observaciones detectadas en el código. El anexo incluye la matriz de trazabilidad entre historias y requerimientos.

2. Descripción general

2.1 Perspectiva del producto

TechnoStore es una aplicación web de tres capas:

- **Frontend:** una página única (index.php) con HTML, CSS y JavaScript que consume la API mediante peticiones HTTP y muestra vistas de catálogo, carrito, pedidos, perfil y panel de administración.
- **Backend:** la API (api.php) expone acciones identificadas por el parámetro action y responde en JSON. La lógica crítica se apoya en procedimientos almacenados, vistas y transacciones de MySQL.
- **Datos:** base de datos MySQL/MariaDB llamada catalogo_ecommerce.
- **Servicios auxiliares:** reporte.php genera reportes en formato .xlsx; mailer.php envía correos mediante PHPMailer y SMTP; y la API consulta servicios externos para la lista de países (restcountries.com) y para el autocompletado de ciudades (Nominatim, OpenStreetMap).

2.2 Funciones del producto

El producto se organiza en diez módulos funcionales:

- **M1. Catálogo público:** listado, búsqueda, filtros, detalle, destacados y datos de la tienda.
- **M2. Cuentas y sesiones:** registro, inicio y cierre de sesión, perfil y cambio de contraseña.
- **M3. Carrito y pedidos:** gestión del carrito, confirmación de pedidos, historial y cancelación por el cliente.

- **M4. Dinero digital:** consulta de saldo, recargas, pagos, movimientos, reembolsos y comprobantes.
- **M5. Catálogo administrativo:** productos, categorías, stock, imágenes y restauración de elementos dados de baja.
- **M6. Pedidos administrativos:** consulta de todos los pedidos, cambio de estado y cancelación con reembolso.
- **M7. Usuarios:** consulta, cambio de rol, edición, restablecimiento de contraseña y baja de usuarios.
- **M8. Personalización:** nombre, colores, logo, banner y datos de contacto de la tienda.
- **M9. Reportes:** descarga de reportes de pedidos, usuarios y productos en Excel.
- **M10. Notificaciones:** correos por registro de pedido y por cambio de estado.

2.3 Clases de usuario

Clase de usuario	Descripción	Permisos principales
Visitante	Persona sin sesión iniciada.	Ver catálogo, buscar, ver detalle, ver destacados, ver datos de la tienda, registrarse e iniciar sesión.
Cliente	Usuario registrado con rol CLIENTE.	Todo lo del visitante, más carrito, pedidos propios, perfil, saldo digital y comprobantes propios.
Administrador	Usuario con rol ADMINISTRADOR.	Gestión de catálogo, pedidos, usuarios, personalización y reportes; consulta de comprobantes de cualquier cliente; recarga de saldo a cualquier usuario.

Un visitante no puede agregar productos al carrito ni confirmar pedidos. El sistema responde con el mensaje «Debes iniciar sesión» (código 401) y le pide autenticarse. Un administrador no puede cambiar su propio rol ni eliminar su propia cuenta.

2.4 Entorno operativo

- **Servidor web y lenguaje:** PHP con las extensiones PDO MySQL, ZIP (para generar reportes) y las funciones de procesamiento de imágenes de PHP.
- **Base de datos:** MySQL 8.0.16 o superior (requerido para aplicar las restricciones CHECK) o MariaDB equivalente, con motor InnoDB.
- **Gestión de dependencias:** Composer, con phpmailer/phpmailer en versión ^7.1.
- **Entorno de desarrollo de referencia:** XAMPP.
- **Navegadores:** versiones actuales de Chrome, Edge, Firefox y Safari.
- **Zona horaria:** America/Bogotá (usada en los reportes).
- **Idioma:** interfaz y mensajes en español.

2.5 Restricciones de diseño

- **Moneda única:** todos los precios y montos están en COP, con formato de miles con punto (por ejemplo, $1.599.000).

- **Pagos:** solo el método Dinero digital procesa un cobro dentro del sistema. Los métodos Tarjeta crédito, PSE, Nequi y Contraentrega registran el pedido en estado PENDIENTE sin cobrar ni verificar un pago real.
- **Autenticación:** basada en sesiones de PHP (cookie de sesión del servidor), no en tokens JWT.
- **Lógica de negocio:** concentrada en procedimientos almacenados y transacciones de base de datos.
- **Imágenes:** máximo 2 MB por archivo, en formatos JPG, PNG, GIF o WEBP.
- **Esquema de base de datos:** la API actualiza automáticamente el esquema en la primera sesión (migración idempotente), sin scripts manuales adicionales.

2.6 Supuestos y dependencias

- El servidor tiene configurado un servidor SMTP cuando la constante MAIL_ENABLED está activa. Si está desactivada, el sistema funciona sin enviar correos.
- Los servicios externos de países y ciudades están disponibles. Si no responden, el sistema debe permitir que el usuario complete país y ciudad manualmente.
- Las imágenes de productos pueden estar en la carpeta local img/ o alojadas en una URL http(s) externa.
- Los usuarios de ejemplo del script SQL tienen contraseñas provisionales (ver sección 8).
- El tiempo de respuesta de los servicios de consulta depende de la conectividad del servidor.

3. Historias de usuario

Cada historia sigue el formato "Como [actor], quiero [acción], para [beneficio]" e incluye sus criterios de aceptación, su prioridad y los requerimientos funcionales (RF) que la cumplen. Prioridad Alta: necesaria para la operación. Media: importante, con alternativa. Baja: mejora deseable.

3.1 Épica E1: Catálogo público y búsqueda

HU-01 · Explorar el catálogo. Como visitante, quiero ver los productos disponibles organizados por categoría, para encontrar lo que necesito sin iniciar sesión.

- Solo aparecen productos activos, de categorías activas y con stock mayor a cero.
- Cada producto muestra nombre, marca, precio en COP, imagen y categoría.
- Un producto agotado no aparece en el catálogo público.
- Prioridad: Alta. RF: RF-01.

HU-02 · Buscar productos. Como visitante, quiero buscar por nombre o marca (por ejemplo, "Sony"), para encontrar rápidamente un producto.

- La búsqueda acepta coincidencias parciales y no distingue mayúsculas ni tildes.
- Solo muestra productos disponibles.
- Si no hay coincidencias, la pantalla indica que no hay resultados.
- Prioridad: Alta. RF: RF-02.

HU-03 · Filtrar el catálogo. Como visitante, quiero filtrar la lista por texto (nombre, marca o categoría) y por categoría, para acotar los resultados.

- Las categorías que se ofrecen como filtro son solo las activas.

- Prioridad: Media. RF: RF-03.

HU-04 · Ver el detalle de un producto. Como visitante, quiero abrir un producto para leer su descripción, especificaciones, precio y stock.

- Si el producto ya no está disponible, el sistema muestra "Este producto ya no está disponible".
- Prioridad: Media. RF: RF-04.

HU-05 · Ver productos destacados. Como visitante, quiero ver los productos destacados en la página principal, para conocer las mejores opciones.

- Solo se muestran productos destacados que cumplan las condiciones de disponibilidad.
- Prioridad: Media. RF: RF-05.

HU-06 · Conocer la tienda. Como visitante, quiero ver el nombre, la descripción y los datos de contacto de la tienda, para tener confianza al comprar.

- Se muestra la configuración más reciente guardada por el administrador.
- Prioridad: Baja. RF: RF-06.

3.2 Épica E2: Cuenta de usuario

HU-07 · Registrarme. Como visitante, quiero crear una cuenta con mis datos, para poder comprar y consultar mis pedidos.

- Son obligatorios nombre, apellido, correo y contraseña. El correo debe tener formato válido y no puede estar registrado.
- La contraseña debe tener al menos 6 caracteres.
- Debo leer los Términos y Condiciones hasta el final y aceptarlos para crear la cuenta.
- El rol asignado siempre es CLIENTE; el formulario no permite elegir otro rol.
- Al terminar, la sesión queda iniciada.
- Prioridad: Alta. RF: RF-07.

HU-08 · Iniciar sesión. Como cliente o administrador, quiero iniciar sesión con mi correo y contraseña, para acceder a mi cuenta.

- Si las credenciales son incorrectas, el mensaje es genérico ("Correo o contraseña incorrectos") y no revela cuál dato es erróneo.
- Solo pueden iniciar sesión las cuentas activas.
- Prioridad: Alta. RF: RF-08.

HU-09 · Cerrar sesión. Como usuario, quiero cerrar mi sesión, para proteger mi cuenta en un equipo compartido.

- Al cerrar sesión, las funciones que requieren autenticación dejan de estar disponibles.
- Prioridad: Alta. RF: RF-09.

HU-10 · Actualizar mi perfil. Como cliente, quiero editar mi nombre, apellido, teléfono y dirección de entrega, para no tener que escribirlos en cada compra.

- El correo no se puede cambiar desde el perfil del cliente.

- La dirección guardada se sugiere automáticamente al confirmar un pedido.
- Prioridad: Media. RF: RF-11.

HU-11 · Cambiar mi contraseña. Como usuario, quiero cambiar mi contraseña escribiendo la actual, para mantener segura mi cuenta.

- La contraseña actual debe ser correcta.
- La nueva contraseña debe tener al menos 6 caracteres.
- Prioridad: Media. RF: RF-12.

3.3 Épica E3: Carrito y compra

HU-12 · Agregar productos al carrito. Como cliente, quiero agregar productos al carrito con la cantidad que necesito.

- Para agregar productos debo haber iniciado sesión; si no, el sistema me lo pide.
- Si el producto ya está en el carrito, la cantidad se suma.
- La cantidad total no puede superar el stock disponible.
- Prioridad: Alta. RF: RF-14.

HU-13 · Gestionar las cantidades del carrito. Como cliente, quiero cambiar la cantidad de un producto o quitarlo del carrito, para ajustar mi compra.

- Si la cantidad es cero o menor, el producto se quita del carrito.
- Si la cantidad supera el stock, el sistema indica cuántas unidades hay disponibles.
- Puedo vaciar el carrito completo.
- Prioridad: Alta. RF: RF-15, RF-16, RF-17.

HU-14 · Confirmar mi pedido. Como cliente, quiero confirmar mi compra indicando la dirección de envío y el método de pago, para recibir los productos.

- La dirección debe tener al menos 6 caracteres. País, ciudad y barrio son obligatorios.
- Debo elegir uno de los cinco métodos de pago disponibles.
- Al confirmar, el stock se descuenta y el precio de cada producto queda fijo para ese pedido.
- Un doble clic no puede generar dos cobros ni dos pedidos.
- Prioridad: Alta. RF: RF-18, RF-19.

HU-15 · Pagar con dinero digital. Como cliente, quiero pagar mi pedido con mi saldo digital, para que quede pagado de inmediato.

- Antes de confirmar, veo mi saldo, el total del pedido y el saldo que quedaría.
- Si el saldo no alcanza, no se descuenta nada, no se reserva stock y el sistema ofrece recargar o elegir otro método.
- Si el saldo alcanza, el pedido queda en estado PAGADO, el saldo disminuye y se genera un comprobante.
- Prioridad: Alta. RF: RF-25, RF-26.

HU-16 · Registrar un pedido con otro método de pago. Como cliente, quiero elegir tarjeta crédito, PSE, Nequi o contraentrega, para dejar registrado mi pedido.

- El pedido queda en estado PENDIENTE hasta que el administrador lo confirme.
- El sistema no cobra ni verifica el pago en estos métodos.
- Prioridad: Media. RF: RF-19.

HU-17 · Recibir correos de mis pedidos. Como cliente, quiero recibir un correo al registrar un pedido y cada vez que cambie su estado, para estar informado.

- El correo incluye número de pedido, productos, cantidades, total, dirección y método de pago.
- Si el envío del correo falla, el pedido se guarda igualmente.
- Prioridad: Media. RF: RF-50.

3.4 Épica E4: Dinero digital

HU-18 · Consultar mi saldo. Como cliente, quiero ver mi saldo disponible en todo momento, para saber si me alcanza para comprar.

- Con sesión iniciada, el saldo aparece en la barra de navegación.
- El saldo se actualiza después de cada recarga o pago.
- Prioridad: Media. RF: RF-23.

HU-19 · Recargar mi saldo. Como cliente, quiero recargar mi saldo con montos rápidos o con un monto personalizado, para poder pagar mis pedidos.

- El monto debe ser mayor que cero y no puede superar $10.000.000 por operación.
- Hay botones de recarga rápida de $50.000, $200.000 y $1.000.000.
- Prioridad: Alta. RF: RF-24.

HU-20 · Revisar mis movimientos. Como cliente, quiero ver mis últimos movimientos (recargas, pagos y reembolsos), con el saldo antes y después de cada uno.

- Se muestran los 50 movimientos más recientes, del más nuevo al más antiguo.
- Los pagos y reembolsos asociados a un pedido muestran el número de pedido y, si existe, el comprobante.
- Prioridad: Media. RF: RF-28.

HU-21 · Consultar e imprimir un comprobante. Como cliente, quiero ver e imprimir el comprobante de cada pago, para tener soporte de mi compra.

- El comprobante muestra número, cliente, pedido, estado, fecha, método de pago, productos con precio unitario y subtotal, y el total pagado.
- Solo el cliente dueño del pedido o un administrador puede verlo.
- Prioridad: Media. RF: RF-29.

HU-22 · Recargar el saldo de un usuario. Como administrador, quiero recargar el saldo digital de un usuario, para atender casos especiales.

- La recarga respeta el límite de $10.000.000 por operación y queda registrada en los movimientos del usuario.
- Prioridad: Baja. RF: RF-30.

3.5 Épica E5: Seguimiento y cancelación de pedidos

HU-23 · Ver mis pedidos. Como cliente, quiero ver mis pedidos con su estado, fechas, método de pago y total, para saber en qué punto va cada compra.

- Los pedidos se ordenan del más reciente al más antiguo.
- Prioridad: Alta. RF: RF-21.

HU-24 · Ver el detalle de un pedido. Como cliente, quiero ver los productos de un pedido con sus cantidades y precios, para verificar mi compra.

- Los precios son los pagados, aunque el precio actual del producto haya cambiado.
- No puedo ver pedidos de otros clientes; el sistema responde "Ese pedido no es tuyo" (403).
- Prioridad: Media. RF: RF-22.

HU-25 · Cancelar un pedido pendiente. Como cliente, quiero cancelar un pedido que aún está pendiente, para no recibir un producto que ya no necesito.

- Solo puedo cancelar pedidos en estado PENDIENTE.
- Al cancelar, el stock vuelve al inventario y el pedido queda CANCELADO.
- Recibo un correo con la cancelación.
- Prioridad: Media. RF: RF-20.

3.6 Épica E6: Administración del catálogo

HU-26 · Crear un producto. Como administrador, quiero registrar un producto con categoría, marca, descripción, especificaciones, precio, stock, imagen y condición de destacado, para ofrecerlo en la tienda.

- El nombre es obligatorio. El precio y el stock no pueden ser negativos.
- La imagen debe ser una ruta relativa (por ejemplo, img/foto.jpg) o una URL http(s) sin espacios.
- La categoría debe existir.
- Prioridad: Alta. RF: RF-31.

HU-27 · Editar un producto. Como administrador, quiero modificar los datos de un producto para mantener la información actualizada.

- Aplican las mismas validaciones de HU-26.
- Prioridad: Media. RF: RF-32.

HU-28 · Ajustar el stock. Como administrador, quiero actualizar la cantidad disponible de un producto para reflejar el inventario real.

- El stock no puede ser negativo.
- Prioridad: Alta. RF: RF-33.

HU-29 · Dar de baja un producto. Como administrador, quiero retirar un producto del catálogo sin perder su historial de ventas.

- La baja es lógica: el producto deja de mostrarse, pero permanece en pedidos y reportes existentes.

- Prioridad: Media. RF: RF-34.

HU-30 · Gestionar categorías. Como administrador, quiero crear, editar y dar de baja categorías para organizar el catálogo.

- El nombre de la categoría es obligatorio.
- Una categoría con productos activos no se puede dar de baja.
- Prioridad: Media. RF: RF-35.

HU-31 · Subir imágenes. Como administrador, quiero subir la imagen de un producto desde mi equipo, para no depender de enlaces externos.

- Formatos permitidos: JPG, PNG, GIF o WEBP, con tamaño máximo de 2 MB.
- El sistema asigna un nombre aleatorio y verifica que el archivo sea una imagen real.
- Prioridad: Media. RF: RF-36.

HU-32 · Restaurar elementos dados de baja. Como administrador, quiero recuperar productos, categorías o usuarios dados de baja por error.

- Un producto no se puede restaurar si su categoría sigue dada de baja.
- Prioridad: Baja. RF: RF-37.

3.7 Épica E7: Administración de pedidos

HU-33 · Ver todos los pedidos. Como administrador, quiero ver la lista de pedidos con los datos del cliente, el total y la dirección de envío.

- Puedo buscar por número de pedido, nombre del cliente o correo.
- No aparecen los carritos que aún no se han confirmado.
- Prioridad: Alta. RF: RF-39.

HU-34 · Cambiar el estado de un pedido. Como administrador, quiero avanzar un pedido por su flujo de estados para reflejar su situación real.

- Solo se permiten las transiciones definidas en RN-06 (sección 7).
- Cada cambio genera un correo al cliente.
- Prioridad: Alta. RF: RF-40.

HU-35 · Cancelar un pedido con reembolso. Como administrador, quiero cancelar un pedido cuando sea necesario, para devolver el stock y el dinero digital al cliente.

- Al cancelar, el stock vuelve al inventario.
- Si el pedido se pagó con dinero digital, el monto se devuelve al saldo del cliente una sola vez (RN-05).
- Prioridad: Alta. RF: RF-41, RF-27.

3.8 Épica E8: Usuarios y roles

HU-36 · Listar usuarios. Como administrador, quiero ver los usuarios activos con su rol y datos de contacto.

- Prioridad: Media. RF: RF-42.

HU-37 · Cambiar el rol de un usuario. Como administrador, quiero asignar el rol CLIENTE o ADMINISTRADOR a un usuario.

- No puedo cambiar mi propio rol (RN-11).
- Prioridad: Media. RF: RF-43.

HU-38 · Editar un usuario y restablecer su contraseña. Como administrador, quiero corregir los datos de un usuario o restablecer su contraseña.

- La nueva contraseña, si se indica, debe tener al menos 6 caracteres. Si se deja vacía, no cambia.
- Prioridad: Media. RF: RF-44.

HU-39 · Dar de baja un usuario. Como administrador, quiero desactivar una cuenta por uso indebido.

- No puedo eliminar mi propia cuenta (RN-11).
- Una cuenta dada de baja no puede iniciar sesión.
- Prioridad: Media. RF: RF-45.

3.9 Épica E9: Personalización y reportes

HU-40 · Personalizar la tienda. Como administrador, quiero cambiar el nombre, los colores, el logo, el banner y los datos de contacto de la tienda.

- El nombre tiene máximo 80 caracteres. Los colores deben tener formato #RRGGBB.
- Cada guardado conserva un registro histórico; la tienda aplica siempre la configuración más reciente (RN-13).
- Prioridad: Media. RF: RF-46.

HU-41 · Descargar reportes en Excel. Como administrador, quiero descargar reportes de pedidos, usuarios y productos en Excel.

- Solo un administrador puede descargar reportes.
- Los reportes de pedidos y de productos incluyen fila de totales.
- Prioridad: Media. RF: RF-47, RF-48, RF-49.

4. Requerimientos funcionales

Cada requerimiento se describe con: acción de la API (parámetro action de api.php), entradas, proceso, salidas, errores (código HTTP y mensaje) y prioridad. Las entradas de tipo texto se recortan (trim) antes de validarse. Todas las respuestas son JSON con la forma {success: boolean, ...} y los errores devuelven {success: false, error: mensaje}.

4.1 M1: Catálogo público

RF-01 · Listar catálogo público. Acción: listar_catalogo (procedimiento sp_listar_catalogo) u obtener_vista_catalogo (vista v_catalogo_publico).

- Entrada: ninguna.

- Proceso: retorna productos con activo = TRUE, categoría con activa = TRUE y stock > 0, ordenados por destacado DESC, categoría ASC y nombre ASC.
- Salida: data = [{id_producto, nombre, marca, categoria, precio, stock, imagen_url, destacado}].
- Errores: 500 "Error de base de datos".
- Prioridad: Alta. HU: HU-01.

RF-02 · Buscar productos. Acción: buscar_productos (procedimiento sp_buscar_productos, parámetro q).

- Entrada: q (texto, máximo 100 caracteres).
- Proceso: filtra por LIKE '%q%' sobre nombre o marca, con los mismos filtros de RF-01. La comparación usa la collation utf8mb4_unicode_ci, que no distingue mayúsculas ni tildes. Ordena por nombre.
- Salida: data = [{id_producto, nombre, marca, categoria, precio, stock, imagen_url, destacado}]. Si no hay coincidencias, data = [].
- Errores: 500 si falla la base de datos.
- Prioridad: Alta. HU: HU-02.

RF-03 · Filtrar por texto y categoría. Acciones: listar_categorias (procedimiento sp_listar_categorias) y listar_catalogo.

- Entrada: texto y categoría seleccionada en la interfaz.
- Proceso: el filtrado se realiza en el cliente (JavaScript) sobre el conjunto devuelto por RF-01. Las categorías ofrecidas son las de sp_listar_categorias (activa = TRUE).
- Salida: subconjunto de productos que cumplen ambos criterios.
- Prioridad: Media. HU: HU-03.

RF-04 · Detalle de producto. Acción: detalle_producto.

- Entrada: id_producto (entero).
- Proceso: consulta v_catalogo_publico por id_producto. Solo devuelve productos disponibles.
- Salida: data = fila completa, incluidos descripcion y especificaciones.
- Errores: 404 "Este producto ya no está disponible" si el producto está inactivo, agotado o su categoría está inactiva.
- Prioridad: Media. HU: HU-04.

RF-05 · Productos destacados. Acción: obtener_destacados.

- Entrada: ninguna.
- Proceso: consulta v_productos_destacados, que es v_catalogo_publico filtrada por destacado = TRUE.
- Salida: data = [{id_producto, nombre, marca, precio, stock, imagen_url, destacado, categoria}].
- Prioridad: Media. HU: HU-05.

RF-06 · Datos de la tienda. Acción: obtener_tienda.

- Entrada: ninguna.
- Proceso: retorna la fila más reciente de personalizacion_tienda (ORDER BY id_personalizacion DESC LIMIT 1).

- Salida: data = {nombre_tienda, descripcion_tienda, logo_url, banner_url, color_primario, color_secundario, correo_contacto, telefono_contacto} o null si no hay configuración.
- Prioridad: Baja. HU: HU-06.

4.2 M2: Cuentas y sesiones

RF-07 · Registro de usuario. Acción: registrar.

- Entradas: nombre, apellido, correo, password, terminos (debe valer "1"), y opcionalmente telefono (máximo 20), direccion (máximo 255), pais, ciudad, barrio (máximo 100 cada uno).
- Validaciones: nombre y apellido no vacíos; correo válido según filter_var(FILTER_VALIDATE_EMAIL); password de al menos 6 caracteres (strlen); terminos = "1".
- Proceso: calcula password_hash(password, PASSWORD_DEFAULT) y ejecuta sp_registrar_usuario, que inserta con rol CLIENTE. Después actualiza pais, ciudad y barrio, ejecuta session_regenerate_id(true) y guarda en $_SESSION['user'] los datos del usuario sin el hash.
- Salida: user = {id_usuario, nombre, apellido, correo, rol: "CLIENTE"}.
- Errores: 400 con mensaje específico por validación; 400 "Ya existe un registro con ese correo o nombre" ante el código MySQL 1062 (clave única).
- Prioridad: Alta. HU: HU-07.

RF-08 · Inicio de sesión. Acción: login.

- Entradas: correo, password.
- Proceso: sp_login_usuario(correo) retorna el usuario solo si activo = TRUE. Se valida con password_verify. Si la cuenta tiene el hash provisional de los datos de ejemplo, ver RN-15 y sección 8. Si la validación es correcta, session_regenerate_id(true) y se guarda $_SESSION['user'] sin contrasena_hash.
- Salida: user = {id_usuario, nombre, apellido, correo, rol}.
- Errores: 401 "Correo o contraseña incorrectos" (mismo mensaje para correo inexistente, cuenta inactiva o contraseña incorrecta).
- Prioridad: Alta. HU: HU-08.

RF-09 · Cierre de sesión. Acción: logout.

- Proceso: $_SESSION = []; session_destroy().
- Salida: success = true. Las acciones posteriores que llaman needLogin() responden 401 "Debes iniciar sesión".
- Prioridad: Alta. HU: HU-09.

RF-10 · Consulta de sesión activa. Acción: sesion.

- Proceso: devuelve $_SESSION['user'] si existe.
- Salida: user = {...}. Sin sesión responde 401 "Sin sesión". La interfaz usa esta respuesta para mostrar u ocultar las opciones de cliente y administrador.
- Prioridad: Alta. HU: transversal a HU-08.

RF-11 · Ver y actualizar perfil. Acciones: perfil_obtener y perfil_actualizar.

- Entradas de actualización: nombre, apellido, telefono, pais, ciudad, barrio, direccion (mismos límites que RF-07).
- Proceso: el UPDATE usa el id de la sesión, no un id enviado por el cliente. El correo no se incluye en el UPDATE, por lo que no es modificable desde el perfil.
- Salida: user actualizado.
- Prioridad: Media. HU: HU-10.

RF-12 · Cambio de contraseña. Acción: cambiar_password.

- Entradas: password_actual, password_nueva.
- Validaciones: password_verify(password_actual, hash) debe ser verdadero; password_nueva de al menos 6 caracteres.
- Proceso: actualiza contrasena_hash con password_hash y ejecuta session_regenerate_id(true).
- Errores: 400 "La contraseña actual no es correcta"; 400 "La nueva contraseña debe tener al menos 6 caracteres".
- Prioridad: Media. HU: HU-11.

RF-13 · Control de acceso por rol y pertenencia. Funciones: needLogin(), needAdmin() y comprobación de pertenencia en detalle_pedido y obtener_comprobante.

- Reglas: las acciones de administración exigen $_SESSION['user']['rol'] = 'ADMINISTRADOR' (403 "Solo para administradores"). Un cliente solo puede consultar pedidos y comprobantes cuyo id_usuario coincida con su sesión (403 "Ese pedido no es tuyo" o 404 "Comprobante no encontrado").
- Regla de seguridad: ninguna acción toma el id de usuario del cliente desde la entrada; siempre se usa el id de la sesión.
- Prioridad: Alta. HU: transversal, HU-08 a HU-41.

4.3 M3: Carrito y pedidos

RF-14 · Agregar producto al carrito. Acción: agregar_carrito (procedimiento sp_agregar_al_carrito).

- Entradas: id_producto (entero), cantidad (entero, por defecto 1, mínimo 1).
- Requiere sesión (needLogin).
- Proceso: valida que el usuario esté activo y que el producto esté activo. Busca el pedido en estado CARRITO más reciente del usuario y, si no existe, lo crea. Suma la cantidad ya presente en el carrito y verifica que el total no supere producto.stock. Inserta el detalle con ON DUPLICATE KEY UPDATE sobre la clave (id_pedido, id_producto).
- Salida: message = "Producto añadido al carrito".
- Errores: 401 "Debes iniciar sesión"; 400 "La cantidad debe ser mayor a 0"; 400 "Producto no existe o está inactivo"; 400 "Stock insuficiente para esa cantidad".
- Prioridad: Alta. HU: HU-12.

RF-15 · Ver carrito. Acción: ver_carrito.

- Proceso: une pedido (estado CARRITO), detalle_pedido, producto y categoría del usuario de sesión. El subtotal se calcula como cantidad × precio actual del producto. Adicionalmente retorna direccion, pais, ciudad y barrio del perfil para precargar el formulario de envío.

- Salida: data = [{id_detalle, id_producto, nombre, marca, imagen_url, categoria, precio, stock, cantidad, subtotal}], direccion, pais, ciudad, barrio.
- Prioridad: Alta. HU: HU-13.

RF-16 · Modificar cantidad o quitar producto. Acción: actualizar_carrito.

- Entradas: id_producto, cantidad.
- Proceso: si cantidad <= 0 elimina la línea del detalle. Si no, verifica que el producto esté activo y que cantidad <= stock, y actualiza la línea.
- Errores: 400 "Tu carrito está vacío" si no existe carrito; 400 "El producto ya no está disponible"; 400 "Solo hay {stock} unidades disponibles".
- Prioridad: Alta. HU: HU-13.

RF-17 · Vaciar carrito. Acción: vaciar_carrito.

- Proceso: elimina todas las líneas de detalle_pedido del carrito del usuario. El pedido CARRITO se conserva vacío.
- Prioridad: Media. HU: HU-13.

RF-18 · Confirmar pedido. Acción: confirmar_pedido.

- Entradas: direccion_envio (mínimo 6 caracteres, máximo 255), pais_envio, ciudad_envio, barrio_envio (obligatorios, máximo 100 cada uno), metodo_pago (uno de: "Tarjeta crédito", "PSE", "Nequi", "Contraentrega", "Dinero digital").
- Proceso en una transacción (BEGIN / COMMIT, con ROLLBACK ante cualquier excepción):
    a. Bloquea el pedido con SELECT ... FOR UPDATE. Si su estado no es CARRITO, responde "Este pedido ya fue procesado".
    b. Bloquea las líneas del detalle y los productos con FOR UPDATE. Si el carrito está vacío, responde "Tu carrito está vacío".
    c. Verifica cantidad <= stock de cada producto. Si no, responde "Stock insuficiente de {producto} (quedan {stock})".
    d. Descuenta el stock de cada producto.
    e. Copia producto.precio en detalle_pedido.precio_unitario (precio congelado).
    f. Actualiza el pedido: estado = PAGADO si el método es Dinero digital, o PENDIENTE en los demás casos; asigna fecha_compra = NOW() y guarda metodo_pago y la dirección.
    g. Si el método es Dinero digital, ejecuta RF-25 y RF-26 dentro de la misma transacción.
- Después del COMMIT se envía el correo de RF-50 (fuera de la transacción).
- Salida: id_pedido y, para Dinero digital, comprobante (número) y saldo (saldo restante).
- Errores: 400 con el mensaje correspondiente a cada validación o a la excepción de la transacción.
- Prioridad: Alta. HU: HU-14, HU-15, HU-16.

RF-19 · Métodos de pago. Regla transversal de RF-18.

- Los métodos Tarjeta crédito, PSE, Nequi y Contraentrega solo cambian el estado del pedido a PENDIENTE. No ejecutan ningún cobro ni verificación con un proveedor externo.
- El único método que ejecuta un cobro real dentro del sistema es Dinero digital.
- Prioridad: Alta. HU: HU-16.

RF-20 · Cancelar pedido por el cliente. Acción: cancelar_pedido.

- Entrada: id_pedido.
- Proceso en transacción: bloquea el pedido con FOR UPDATE filtrando por id_usuario de la sesión. Solo procede si el estado es PENDIENTE. Devuelve el stock de cada línea y actualiza el estado a CANCELADO.
- Errores: 400 "Pedido no encontrado"; 400 "Solo puedes cancelar pedidos pendientes".
- Post-condición: envío de correo (RF-50).
- Prioridad: Media. HU: HU-25.

RF-21 · Historial de pedidos del cliente. Acción: pedidos_usuario.

- Proceso: retorna los pedidos del usuario de sesión (cualquier estado distinto de CARRITO no es requerido; la consulta devuelve todos los estados, incluido CARRITO, si existe). Calcula el total como SUM(cantidad × COALESCE(precio_unitario, precio actual)).
- Salida: data = [{id_pedido, estado, fecha_creacion, fecha_compra, metodo_pago, pais_envio, ciudad_envio, barrio_envio, direccion_envio, total}] ordenada por fecha_creacion DESC, id_pedido DESC.
- Prioridad: Alta. HU: HU-23.

RF-22 · Detalle de un pedido. Acción: detalle_pedido.

- Entrada: id_pedido.
- Proceso: si el usuario no es administrador, verifica que el pedido pertenezca a su id de sesión (403 "Ese pedido no es tuyo"). Retorna las líneas con precio_unitario = COALESCE(precio_unitario histórico, precio actual) y subtotal.
- Prioridad: Media. HU: HU-24.

4.4 M4: Dinero digital

El saldo digital es un valor simulado guardado en usuario.saldo_digital (DECIMAL(12,2), mínimo 0, valor inicial 10000000.00). Toda modificación de saldo se realiza con la función moverSaldo(), que debe ejecutarse dentro de una transacción y bloquea la fila del usuario con SELECT ... FOR UPDATE. Cada modificación inserta un registro en transaccion_digital con saldo_anterior y saldo_posterior.

RF-23 · Consultar saldo. Acción: saldo_digital.

- Requiere sesión. Retorna saldo = saldo_digital del usuario de sesión (número decimal).
- Prioridad: Media. HU: HU-18.

RF-24 · Recargar saldo propio. Acción: recargar_saldo.

- Entradas: monto (numérico, mayor que 0, máximo 10000000 por operación, redondeado a 2 decimales); id_usuario (opcional, solo para administrador, ver RF-30).
- Proceso: moverSaldo(usuario, 'RECARGA', monto) dentro de tx().
- Salida: saldo (nuevo saldo), message = "Recarga realizada".
- Errores: 400 "Escribe un monto válido"; 400 "El monto debe ser mayor que cero"; 400 "La recarga máxima por operación es $10.000.000".
- Prioridad: Alta. HU: HU-19.

RF-25 · Pago con dinero digital. Función moverSaldo(usuario, 'PAGO', total, id_pedido), invocada desde RF-18.

- El total se calcula con totalPedido(): SUM(cantidad × precio_unitario) de las líneas del pedido, que ya están congeladas.
- Si saldo_anterior - total < 0, lanza RuntimeException "Saldo digital insuficiente: tienes $X y el pedido cuesta $Y". Como la excepción ocurre dentro de la transacción de RF-18, se revierten el descuento de stock, el cambio de estado y la congelación de precios.
- Registro: transaccion_digital con tipo = PAGO, monto, saldo_anterior, saldo_posterior e id_pedido.
- Prioridad: Alta. HU: HU-15.

RF-26 · Emisión de comprobante. Función emitirComprobante(), invocada desde RF-18.

- Inserta en comprobante (id_pedido, id_usuario, id_transaccion, monto). La restricción UNIQUE sobre id_pedido impide un segundo comprobante para el mismo pedido.
- Asigna numero = 'COMP-' + id_comprobante con seis dígitos rellenados con ceros (ejemplo: COMP-000001). Después del insert se hace un UPDATE del número, porque se necesita el id autoincremental.
- Prioridad: Alta. HU: HU-15, HU-21.

RF-27 · Reembolso de dinero digital. Función reembolsarPedido(id_pedido), invocada desde RF-41.

- Si no existe un movimiento PAGO para el pedido, no hace nada (pedido pagado con otro método).
- Si ya existe un movimiento REEMBOLSO para el pedido, no hace nada (idempotencia).
- En otro caso, ejecuta moverSaldo(usuario, 'REEMBOLSO', monto, id_pedido).
- Prioridad: Alta. HU: HU-35.

RF-28 · Consultar movimientos. Acción: movimientos_saldo.

- Proceso: retorna los últimos 50 registros de transaccion_digital del usuario, ordenados por id_transaccion DESC, con el número de comprobante asociado (LEFT JOIN comprobante por id_transaccion).
- Salida: data = [{id_transaccion, tipo, monto, saldo_anterior, saldo_posterior, fecha, id_pedido, comprobante}].
- Prioridad: Media. HU: HU-20.

RF-29 · Consultar comprobante. Acción: obtener_comprobante.

- Entrada: id_pedido.
- Proceso: une comprobante, pedido y usuario. Si el usuario de sesión no es administrador y no es el dueño, responde 404 "Comprobante no encontrado" (no revela la existencia del recurso). Incluye items = líneas del pedido con precio_unitario y subtotal.
- Salida: data = {numero, monto, fecha_emision, id_pedido, metodo_pago, estado, cliente, correo, items}.
- Prioridad: Media. HU: HU-21.

RF-30 · Recarga de saldo por administrador. Acción: recargar_saldo con id_usuario.

- Solo si el rol de sesión es ADMINISTRADOR y se envía id_usuario, la recarga se aplica al usuario indicado. Si el rol es CLIENTE, el parámetro id_usuario se ignora y la recarga se aplica al propio usuario.
- Mismas validaciones que RF-24.
- Prioridad: Baja. HU: HU-22.

4.5 M5: Catálogo administrativo

Todas las acciones de este módulo requieren rol ADMINISTRADOR (RF-13).

RF-31 · Crear producto. Acción: crear_producto (procedimiento sp_crear_producto).

- Entradas: id_categoria (entero, debe existir), nombre (obligatorio, máximo 150), marca (máximo 80), descripcion (TEXT), especificaciones (TEXT), precio (decimal >= 0, DECIMAL(12,2)), stock (entero >= 0), imagen_url (máximo 255; ruta relativa o URL http(s) sin espacios, comillas, paréntesis ni signos <>), destacado (booleano).
- Errores: 400 "Revisa nombre, precio y stock"; 400 "La imagen debe ser una ruta como img/foto.jpg o una URL http(s) sin espacios"; error de clave foránea de categoría traducido a 500 "Error de base de datos".
- Prioridad: Alta. HU: HU-26.

RF-32 · Editar producto. Acción: actualizar_producto (procedimiento sp_actualizar_producto).

- Mismas entradas y validaciones de RF-31, más id_producto.
- Errores: 400 "El producto no existe" si el id no está activo; 400 "Precio y stock no pueden ser negativos".
- Prioridad: Media. HU: HU-27.

RF-33 · Ajustar stock. Acción: actualizar_stock (procedimiento sp_actualizar_stock).

- Entradas: nombre_producto, nuevo_stock (entero).
- Proceso: busca el producto por nombre exacto. Si nuevo_stock < 0, rechaza. Si el nombre no existe, rechaza. Actualiza stock.
- Errores: 400 "El stock no puede ser negativo"; 400 "El producto no existe".
- Nota: el identificador es el nombre y no el id. Ver sección 8, observación O-06.
- Prioridad: Alta. HU: HU-28.

RF-34 · Baja lógica de producto. Acción: eliminar_producto (procedimiento sp_eliminar_producto).

- Proceso: UPDATE producto SET activo = FALSE. No elimina filas, por lo que el historial de detalle_pedido se conserva.
- Efecto: el producto deja de aparecer en RF-01, RF-02, RF-04 y RF-05.
- Prioridad: Media. HU: HU-29.

RF-35 · Gestionar categorías. Acciones: crear_categoria, actualizar_categoria, eliminar_categoria.

- Crear: nombre obligatorio, descripcion opcional (máximo 255). Procedimiento sp_crear_categoria.
- Actualizar: id_categoria, nombre obligatorio. Procedimiento sp_actualizar_categoria. Error 400 "La categoría no existe" si la categoría no está activa.

- Eliminar (baja lógica): procedimiento sp_eliminar_categoria. Si existe algún producto activo con esa categoría, responde 400 "No puedes eliminar una categoría que tiene productos activos". Si no, UPDATE categoria SET activa = FALSE.
- Prioridad: Media. HU: HU-30.

RF-36 · Subir imagen de producto. Acción: subir_imagen (multipart/form-data, campo archivo).

- Validaciones: tamaño <= 2 MB (2097152 bytes); getimagesize() debe identificar IMAGETYPE_JPEG, IMAGETYPE_PNG, IMAGETYPE_GIF o IMAGETYPE_WEBP. La extensión la asigna el servidor según el tipo detectado, no el nombre original.
- Proceso: crea img/uploads si no existe (permisos 0755), genera nombre aleatorio de 16 caracteres hexadecimales (random_bytes(8)) y mueve el archivo con move_uploaded_file.
- Salida: ruta = "img/uploads/{nombre}".
- Errores: 400 "La imagen supera el máximo de 2 MB"; 400 "Formato no válido: usa JPG, PNG, GIF o WEBP"; 500 si no se puede crear la carpeta o guardar el archivo.
- Prioridad: Media. HU: HU-31.

RF-37 · Restaurar elemento dado de baja. Acción: restaurar (parámetros tipo e id).

- tipo = producto: solo si p.activo = FALSE y la categoría tiene activa = TRUE; de lo contrario responde 400 "Primero restaura la categoría de este producto".
- tipo = categoria: UPDATE categoria SET activa = TRUE, solo si activa = FALSE.
- tipo = usuario: UPDATE usuario SET activo = TRUE, solo si activo = FALSE.
- Otro tipo: 400 "Tipo no válido".
- Acción complementaria: listar_eliminados (tipo) lista los elementos dados de baja.
- Prioridad: Baja. HU: HU-32.

RF-38 · Listar productos del panel. Acción: admin_productos (procedimiento sp_admin_listar_productos).

- Proceso: retorna todos los productos activos, incluidos los agotados (stock = 0) y los de categorías inactivas, con descripcion y especificaciones.
- Prioridad: Alta. HU: transversal a HU-26 a HU-29.

4.6 M6: Pedidos administrativos

RF-39 · Listar pedidos. Acción: admin_pedidos.

- Proceso: retorna los pedidos con estado distinto de CARRITO, unidos a usuario (nombre, apellido, correo, telefono) y con total calculado. Ordena por fecha_creacion DESC, id_pedido DESC.
- Búsqueda: se realiza en la interfaz sobre el conjunto devuelto, por número de pedido, nombre o correo.
- Prioridad: Alta. HU: HU-33.

RF-40 · Cambiar estado de pedido. Acción: cambiar_estado_pedido.

- Entradas: id_pedido, estado (nuevo).

- Proceso en transacción: bloquea el pedido con FOR UPDATE. Valida la transición contra la matriz de RN-06. Si es válida y el nuevo estado es CANCELADO, ejecuta RF-41. Actualiza el estado. Después de COMMIT envía el correo de RF-50.
- Errores: 400 "Pedido no encontrado"; 400 "No se puede pasar un pedido de {actual} a {nuevo}".
- Prioridad: Alta. HU: HU-34.

RF-41 · Cancelar pedido por el administrador. Parte de cambiar_estado_pedido con nuevo estado CANCELADO.

- Desde PENDIENTE, PAGADO o ENVIADO.
- Restaura el stock: UPDATE producto JOIN detalle_pedido ... SET stock = stock + cantidad.
- Invoca RF-27 para devolver el dinero digital, si aplica.
- Prioridad: Alta. HU: HU-35.

4.7 M7: Usuarios

Todas las acciones de este módulo requieren rol ADMINISTRADOR (RF-13).

RF-42 · Listar usuarios. Acción: listar_usuarios.

- Proceso: retorna usuarios con activo = TRUE, ordenados por fecha_registro DESC, id_usuario DESC. No incluye contrasena_hash.
- Prioridad: Media. HU: HU-36.

RF-43 · Cambiar rol. Acción: cambiar_rol (procedimiento sp_cambiar_rol).

- Entradas: id_usuario, rol (ADMINISTRADOR o CLIENTE).
- Errores: 400 "No puedes cambiar tu propio rol" (RN-11); 400 "Rol no válido" (valor fuera del enumerado).
- Prioridad: Media. HU: HU-37.

RF-44 · Editar usuario y restablecer contraseña. Acción: admin_actualizar_usuario.

- Entradas: id_usuario, nombre, apellido, correo (validado), telefono, pais, ciudad, barrio, direccion, password (opcional).
- Proceso: si password no está vacío, se guarda password_hash(password). Si el usuario editado es el de sesión, actualiza $_SESSION['user'].
- Errores: 400 "Correo no válido"; 400 "La contraseña debe tener al menos 6 caracteres"; 404 "Usuario no encontrado".
- Prioridad: Media. HU: HU-38.

RF-45 · Baja lógica de usuario. Acción: eliminar_usuario (procedimiento sp_eliminar_usuario).

- Proceso: UPDATE usuario SET activo = FALSE. El login (RF-08) deja de aceptar la cuenta.
- Errores: 400 "No puedes eliminar tu propia cuenta" (RN-11).
- Prioridad: Media. HU: HU-39.

4.8 M8: Personalización de la tienda

RF-46 · Guardar configuración de tienda. Acciones: tienda_admin (lectura) y guardar_tienda (escritura).

- Entradas: nombre_tienda (obligatorio, máximo 80), color_primario y color_secundario (formato #RRGGBB, expresión regular /^#[0-9a-fA-F]{6}$/), logo_url y banner_url (ruta o URL segura, máximo 255), descripcion_tienda, correo_contacto (opcional, validado con FILTER_VALIDATE_EMAIL, máximo 120), telefono_contacto (máximo 20).
- Proceso: INSERT en personalizacion_tienda (nueva fila; no hay UPDATE). La relación con usuario es 1:N, con la fila más reciente vigente (RN-13).
- Errores: 400 con el mensaje de validación correspondiente.
- Prioridad: Media. HU: HU-40.

4.9 M9: Reportes

Los reportes se generan en reporte.php, no en api.php. Requieren sesión de ADMINISTRADOR (403 si el rol no coincide, 401 si no hay sesión). Responden un archivo .xlsx con cabecera Content-Disposition, o JSON con success = false en caso de error. La zona horaria es America/Bogotá. Los importes usan COALESCE(d.precio_unitario, pr.precio) para no alterar reportes históricos.

RF-47 · Reportes de pedidos por estado. Parámetro tipo: pedidos_entregados (estado ENTREGADO), pedidos_pendientes (PENDIENTE) o pedidos_enviados (ENVIADO).

- Libro con dos hojas: "Pedidos" (número, cliente, correo, teléfono, fechas, método de pago, dirección, unidades, total) con fila de totales, y "Detalle de productos" (pedido, producto, marca, categoría, cantidad, precio unitario, subtotal) con fila de totales.
- Prioridad: Media. HU: HU-41.

RF-48 · Reportes de usuarios. Parámetro tipo: usuarios_con_pedidos o usuarios_sin_pedidos.

- Con pedidos: pedidos realizados (todos los estados distintos de CARRITO), cancelados, total comprado (excluye cancelados), último pedido.
- Sin pedidos: usuarios sin ningún registro en pedido con estado distinto de CARRITO.
- Prioridad: Media. HU: HU-41.

RF-49 · Ranking de productos. Parámetro tipo: productos_mas_menos_comprados.

- Columnas: posición, id, producto, marca, categoría, unidades vendidas, número de pedidos, ingresos, stock actual, estado del producto. Considera solo pedidos PENDIENTE, PAGADO, ENVIADO y ENTREGADO. Se incluye fila de totales.
- Prioridad: Media. HU: HU-41.

4.10 M10: Notificaciones por correo

RF-50 · Notificación de estado de pedido. Función notificarPedido(id_pedido), invocada después del COMMIT en confirmar_pedido, cancelar_pedido y cambiar_estado_pedido.

- Condición de envío: MAIL_ENABLED = true, el estado está en MAIL_ESTADOS (PENDIENTE, PAGADO, ENVIADO, ENTREGADO, CANCELADO) y el correo del cliente es válido.
- Contenido: encabezado con color por estado, número de pedido, líneas con cantidad y subtotal, total, dirección, método de pago y nombre de la tienda. Todos los valores dinámicos se escapan con htmlspecialchars.

- Transporte: PHPMailer sobre SMTP (MAIL_HOST, MAIL_PORT, MAIL_USER, MAIL_PASS, MAIL_FROM, MAIL_FROM_NAME).
- Tolerancia a fallos: la función captura excepciones y devuelve false. El cambio de estado ya está confirmado en la base de datos.
- Prioridad: Media. HU: HU-17.

5. Requerimientos no funcionales

RNF-01 · Integridad de datos. La base de datos debe rechazar valores inválidos mediante restricciones CHECK: producto.precio >= 0, producto.stock >= 0, detalle_pedido.cantidad > 0, usuario.saldo_digital >= 0 y transaccion_digital.monto > 0. Las claves foráneas usan ON DELETE RESTRICT, salvo detalle_pedido y personalizacion_tienda, que usan CASCADE.

RNF-02 · Concurrencia. Las operaciones que modifican stock o saldo deben ejecutarse en una transacción con bloqueo pesimista (SELECT ... FOR UPDATE) sobre la fila afectada. Dos confirmaciones simultáneas del mismo carrito o de dos pedidos sobre el último stock no deben producir stock negativo ni cobro duplicado. La prueba de referencia es enviar dos peticiones confirmar_pedido en paralelo con el mismo id de carrito y verificar que solo una produzca PAGADO o PENDIENTE.

RNF-03 · Precisión monetaria. Los importes se almacenan como DECIMAL(12,2) en la base de datos. En PHP se redondean con round(valor, 2) antes de operar. No se usan tipos de coma flotante para persistir montos.

RNF-04 · Seguridad de credenciales. Las contraseñas se guardan con password_hash(PASSWORD_DEFAULT), que produce un hash bcrypt de 60 caracteres en la columna VARCHAR(255). La verificación se realiza con password_verify. Ninguna respuesta de la API incluye contrasena_hash.

RNF-05 · Seguridad de sesión. Se invoca session_regenerate_id(true) después de cada autenticación exitosa (registro, login y cambio de contraseña). El cierre de sesión ejecuta session_destroy(). Ver observación O-02 sobre protección CSRF.

RNF-06 · Seguridad de acceso a datos. Todas las consultas con parámetros variables usan sentencias preparadas de PDO con parámetros enlazados. La conexión usa PDO::ERRMODE_EXCEPTION. Los errores de base de datos no exponen detalles en la respuesta (500 "Error de base de datos"), salvo los mensajes SIGNAL definidos por la aplicación (SQLSTATE 45000).

RNF-07 · Seguridad de entrada y salida. Las entradas se recortan con trim(). Los campos de URL pasan una expresión regular que impide comillas, espacios, paréntesis y signos < >. Las imágenes subidas se validan por contenido con getimagesize() y reciben un nombre aleatorio. Los valores dinámicos de los correos se escapan con htmlspecialchars(ENT_QUOTES, 'UTF-8').

RNF-08 · Rendimiento. Objetivo para validar en pruebas de carga: las acciones de catálogo (RF-01, RF-02, RF-05) responden en menos de 500 ms en el percentil 95 con 1.000 productos y 50 peticiones concurrentes. Las acciones de escritura de pedido (RF-18) responden en menos de 1 s en el percentil 95. Estos valores son objetivos de diseño, no mediciones.

RNF-09 · Disponibilidad ante fallos externos. El envío de correo (RNF-09 → RF-50) es asíncrono respecto a la transacción: un fallo de SMTP no revierte el pedido. Los servicios de países y ciudades tienen un tiempo máximo de espera de 12 segundos (timeout en stream_context); si fallan, la API devuelve listas vacías y no bloquea el registro.

RNF-10 · Trazabilidad financiera. Cada cambio de saldo genera un registro en transaccion_digital con tipo, monto, saldo_anterior y saldo_posterior. Los registros no se modifican ni se eliminan desde la aplicación.

RNF-11 · Migración de esquema. La función migrar() se ejecuta una vez por sesión PHP (bandera $_SESSION['mig_ok']). Usa consultas a information_schema antes de cada ALTER TABLE, y tolera el error 1060 (columna duplicada) para que sea idempotente.

RNF-12 · Compatibilidad. PHP 8.0 o superior, con PDO MySQL, ZIP y funciones de imagen. MySQL 8.0.16 o superior (CHECK exigido) o MariaDB 10.5 o superior. Codificación utf8mb4 con collation utf8mb4_unicode_ci. Navegadores modernos (últimas dos versiones de Chrome, Edge, Firefox y Safari).

RNF-13 · Usabilidad y responsive. La interfaz adapta el diseño por debajo de 860 px de ancho (media query). Los formularios muestran mensajes en español y los errores de API se presentan como notificaciones (toast) o diálogos.

RNF-14 · Accesibilidad. Los controles sin texto visible tienen aria-label (por ejemplo, el botón de saldo en la barra de navegación). El saldo se actualiza con aria-live = polite. Debe cumplirse un contraste mínimo de 4.5:1 para texto normal (WCAG 2.1 AA); esta verificación está pendiente.

RNF-15 · Cumplimiento legal. Ley 1581 de 2012: la aceptación de los Términos y Condiciones es obligatoria para crear cuenta (RF-07). Los datos recolectados se limitan a los necesarios para la compra. Ley 1480 de 2011: los Términos mencionan el derecho de retracto de cinco días hábiles; el sistema no implementa un flujo de retracto (ver O-05).

RNF-16 · Mantenibilidad. La lógica transaccional reside en procedimientos almacenados y funciones PHP reutilizables (moverSaldo, totalPedido, emitirComprobante, reembolsarPedido). Los mensajes de error están centralizados en el código de cada acción.

6. Modelo de datos

Base de datos: catalogo_ecommerce (MySQL, motor InnoDB, collation utf8mb4_unicode_ci).

6.1 Tablas

Tabla	Columnas principales	Clave primaria	Restricciones y claves foráneas
usuario	id_usuario, nombre, apellido, correo, contrasena_hash, telefono, pais, ciudad, barrio, direccion, rol, fecha_registro, activo,	id_usuario	correo UNIQUE; rol ENUM(ADMINISTRADOR, CLIENTE), default CLIENTE; saldo_digital DEFAULT 10000000.00;

Tabla	Columnas principales	Clave primaria	Restricciones y claves foráneas
	saldo_digital		CHECK saldo_digital >= 0
categoria	id_categoria, nombre, descripcion, activa	id_categoria	nombre UNIQUE; activa DEFAULT TRUE
producto	id_producto, id_categoria, nombre, marca, descripcion, especificaciones, precio, stock, imagen_url, destacado, activo, fecha_creacion, fecha_actualizacion	id_producto	FK id_categoria → categoria (RESTRICT); CHECK precio >= 0; CHECK stock >= 0; índices en id_categoria y nombre
pedido	id_pedido, id_usuario, estado, fecha_creacion, fecha_compra, metodo_pago, direccion_envio, pais_envio, ciudad_envio, barrio_envio	id_pedido	FK id_usuario → usuario (RESTRICT); estado ENUM(CARRITO, PENDIENTE, PAGADO, ENVIADO, ENTREGADO, CANCELADO)
detalle_pedido	id_detalle, id_pedido, id_producto, cantidad, precio_unitario	id_detalle	FK id_pedido → pedido (CASCADE); FK id_producto → producto (RESTRICT); UNIQUE (id_pedido, id_producto); CHECK cantidad > 0; precio_unitario NULL en carritos
transaccion_digital	id_transaccion, id_usuario, id_pedido, tipo, monto, saldo_anterior, saldo_posterior, fecha	id_transaccion	tipo ENUM(RECARGA, PAGO, REEMBOLSO); CHECK monto > 0; FK id_usuario y id_pedido (RESTRICT); id_pedido NULL en recargas
comprobante	id_comprobante, numero, id_pedido, id_usuario, id_transaccion, monto,	id_comprobante	numero UNIQUE (formato COMP-000000); UNIQUE id_pedido; FK id_pedido, id_usuario e

Tabla	Columnas principales	Clave primaria	Restricciones y claves foráneas
	fecha_emision		id_transaccion (RESTRICT)
personalizacion_tienda	id_personalizacion, id_usuario, nombre_tienda, logo_url, color_primario, color_secundario, banner_url, descripcion_tienda, correo_contacto, telefono_contacto, fecha_actualizacion	id_personalizacion	FK id_usuario → usuario (CASCADE); colores VARCHAR(7) con default #1F4E79 y #FFF2CC

6.2 Vistas

- **v_catalogo_publico:** productos activos de categorías activas con stock > 0. Base de RF-01, RF-04.
- **v_productos_destacados:** v_catalogo_publico filtrada por destacado = TRUE. Base de RF-05.
- **v_stock_bajo:** productos activos con stock <= 5 y su categoría. Ver O-10.
- **v_detalle_pedido_completo:** detalle_pedido unido a producto con subtotal calculado.

6.3 Procedimientos almacenados

SP de escritura: sp_registrar_usuario, sp_crear_categoria, sp_crear_producto, sp_agregar_al_carrito, sp_actualizar_stock, sp_actualizar_categoria, sp_eliminar_categoria, sp_actualizar_producto, sp_eliminar_producto, sp_cambiar_rol, sp_eliminar_usuario. SP de lectura: sp_login_usuario, sp_listar_catalogo, sp_buscar_productos, sp_productos_por_categoria, sp_pedidos_usuario, sp_obtener_tienda, sp_listar_categorias, sp_admin_listar_productos, sp_obtener_producto, sp_listar_usuarios.

Los procedimientos de escritura validan con SIGNAL SQLSTATE '45000' y un MESSAGE_TEXT en español, que la API transforma en respuesta 400 (RNF-06).

7. Reglas de negocio

RN-01 · Reserva de stock. El stock se valida y descuenta al confirmar el pedido (RF-18), no al agregar al carrito. Agregar al carrito solo verifica que la cantidad no supere el stock disponible en ese momento.

RN-02 · Precio congelado. Al confirmar, cada línea guarda el precio vigente en detalle_pedido.precio_unitario. Los cambios posteriores de producto.precio no afectan pedidos existentes, totales, comprobantes ni reportes.

RN-03 · Atomicidad y no duplicación. La confirmación de pedido es todo o nada. Si cualquier paso falla (stock, saldo, comprobante), se revierte la transacción completa. Un pedido solo puede procesarse una vez: si su estado ya no es CARRITO, la segunda petición se rechaza.

RN-04 · Un comprobante por pedido. Cada pedido pagado con dinero digital genera exactamente un comprobante (UNIQUE sobre id_pedido). Los pedidos con otros métodos no generan comprobante.

RN-05 · Reembolso único. Un pedido pagado con dinero digital se reembolsa como máximo una vez. La función reembolsarPedido verifica la existencia de un REEMBOLSO previo para el mismo pedido.

RN-06 · Flujo de estados. Las transiciones permitidas son:

Estado actual	Transiciones permitidas
CARRITO	Se convierte en PENDIENTE o PAGADO al confirmar (RF-18). No tiene transiciones administrativas.
PENDIENTE	PAGADO, CANCELADO
PAGADO	ENVIADO, CANCELADO
ENVIADO	ENTREGADO, CANCELADO
ENTREGADO	Ninguna (estado terminal)
CANCELADO	Ninguna (estado terminal)

Cualquier otra transición se rechaza con el mensaje de RF-40. La matriz está implementada en el arreglo $flujo de cambiar_estado_pedido.

RN-07 · Cancelación por el cliente. El cliente solo puede cancelar pedidos en estado PENDIENTE. Un pedido PAGADO con dinero digital no puede cancelarlo el cliente; solo el administrador (RF-41). Ver O-05.

RN-08 · Límite de recarga. Cada recarga no puede superar $10.000.000 COP. No existe límite acumulado diario ni mensual.

RN-09 · Saldo no negativo. El saldo digital nunca puede ser negativo. Se valida antes del descuento (RF-25) y se refuerza con la restricción CHECK de la base de datos (RNF-01).

RN-10 · Dependencias de baja. Una categoría con productos activos no se puede dar de baja (RF-35). Un producto no se puede restaurar si su categoría está inactiva (RF-37).

RN-11 · Protección de la cuenta administradora. Un administrador no puede cambiar su propio rol (RF-43) ni dar de baja su propia cuenta (RF-45).

RN-12 · Un carrito por usuario. Cada usuario tiene como máximo un pedido en estado CARRITO. Si existen varios, sp_agregar_al_carrito usa el de mayor id_pedido.

RN-13 · Historial de configuración. Cada guardado de personalización inserta una fila nueva en personalizacion_tienda. La tienda muestra la fila con mayor id_personalizacion. Las filas anteriores se conservan.

RN-14 · Baja lógica. Productos, categorías y usuarios se desactivan con activo = FALSE o activa = FALSE. La aplicación no ejecuta DELETE sobre estas tablas, para preservar el historial de pedidos, comprobantes y reportes.

RN-15 · Cuentas provisionales de ejemplo. Las cuentas creadas por el script bdcatalogo.sql tienen un hash marcador que empieza por "$2y$10$hashEjemplo". Mientras ese marcador esté presente, la contraseña "123456" es aceptada en login (RF-08) y en cambiar_password (RF-12), y el hash se reemplaza por uno real en el primer ingreso. Ver O-01.

8. Observaciones técnicas y brechas

Las siguientes observaciones se identificaron durante la revisión del código y de la base de datos. Cada una tiene una severidad (Alta, Media o Baja) y una recomendación. Ninguna está resuelta en la versión actual del código.

O-01 · Contraseña provisional aceptada (Severidad: Alta). Las funciones login y cambiar_password aceptan "123456" para cualquier usuario cuyo hash empiece por "$2y$10$hashEjemplo". Un atacante puede iniciar sesión en esas cuentas si no se han cambiado los datos de ejemplo. Recomendación: eliminar esa rama de código y forzar el cambio de contraseña en el primer ingreso o retirar los datos de ejemplo del entorno productivo.

O-02 · Protección CSRF no evidente (Severidad: Media). Las acciones que modifican estado (POST) no validan un token anti-CSRF. La cookie de sesión sin atributos SameSite explícitos aumenta la exposición. Recomendación: generar un token por sesión, validarlo en cada POST y configurar session.cookie_samesite = Strict o Lax.

O-03 · Sin límite de intentos de inicio de sesión (Severidad: Media). RF-08 no registra intentos fallidos ni bloquea temporalmente la cuenta o la dirección IP. Recomendación: limitar a N intentos por ventana de tiempo y registrar los fallos.

O-04 · Métodos de pago sin cobro real (Severidad: Media). Tarjeta crédito, PSE, Nequi y Contraentrega no ejecutan ningún cobro (RF-19). El estado PENDIENTE depende de que el administrador cambie el estado manualmente. Para uso productivo se requiere integrar un proveedor de pagos y un webhook de confirmación.

O-05 · Discrepancia entre los Términos y el código (Severidad: Media). Los Términos y Condiciones indican que el cliente puede cancelar "mientras no haya sido despachado". El código (RF-20, RN-07) solo permite cancelar pedidos PENDIENTE. Un pedido PAGADO con dinero digital no puede cancelarlo el cliente. Recomendación: alinear el texto legal con el comportamiento o ampliar la regla en el código. Además, el retracto de cinco días (Ley 1480 de 2011) no tiene flujo implementado (RNF-15).

O-06 · Identificación de producto por nombre (Severidad: Media). sp_actualizar_stock (RF-33) busca el producto por nombre, que no es único. Dos productos con el mismo nombre provocan actualizaciones sobre el primero que encuentre la consulta. Recomendación: usar id_producto en el procedimiento y en la API.

O-07 · Credenciales en el paquete del proyecto (Severidad: Alta). El archivo config.php contiene las credenciales de la base de datos y del servidor SMTP. Recomendación: moverlas a variables de entorno o a un archivo fuera del control de versiones, y rotar las credenciales que hayan sido expuestas.

O-08 · Doble definición de sp_buscar_productos (Severidad: Baja). bdcatalogo.sql define el procedimiento dos veces. La segunda definición (con imagen_url y destacado) reemplaza a la primera. El resultado es correcto, pero el script es confuso. Recomendación: eliminar la primera definición.

O-09 · Nombre de marca inconsistente (Severidad: Baja). El encabezado y el título usan "TechnoStore", mientras que el pie de página y el texto de contacto usan "TecnoShop". Recomendación: unificar el nombre en la configuración de la tienda o en la plantilla.

O-10 · Alerta de stock bajo no expuesta (Severidad: Baja). La vista v_stock_bajo existe en la base de datos, pero no hay una acción de API ni una pantalla que la consuma. Los requerimientos de inventario bajo quedan sin cubrir en la interfaz.

O-11 · Compra exige sesión (Severidad: Baja, informativa). agregar_carrito y confirmar_pedido llaman a needLogin(). Un visitante sin cuenta no puede comprar, aunque puede explorar el catálogo. Si el negocio quiere compra como invitado, debe cambiarse RF-14 y RF-18 y diseñar la identificación del invitado.

O-12 · Filtrado y paginación en cliente (Severidad: Baja). RF-01 y RF-02 devuelven todos los resultados sin paginación, y el filtrado de RF-03 se hace en el navegador. Con catálogos grandes aumentará el tiempo de respuesta y el consumo de memoria. Recomendación: paginar por lotes de 24 a 48 productos en el servidor.

O-13 · Dependencia de servicios externos sin caché (Severidad: Baja). obtener_paises y obtener_ciudades consultan restcountries.com y Nominatim en cada petición. Nominatim tiene una política de uso que limita la frecuencia de consultas. Recomendación: cachear la lista de países y limitar la frecuencia de consultas de ciudades.

Anexo A. Matriz de trazabilidad: acción de API, procedimiento y requerimiento

Acción (action)	Archivo	Procedimiento o consulta	RF	Rol requerido
listar_catalogo	api.php	sp_listar_catalogo	RF-01	Público
obtener_vista_catalogo	api.php	v_catalogo_publico	RF-01	Público
buscar_productos	api.php	sp_buscar_productos	RF-02	Público
listar_categorias	api.php	sp_listar_categorias	RF-03	Público
detalle_producto	api.php	v_catalogo_publico	RF-04	Público
obtener_destacados	api.php	v_productos_destacados	RF-05	Público
obtener_tienda	api.php	personalizacion_tienda	RF-06	Público
registrar	api.php	sp_registrar_usuario	RF-07	Público

Acción (action)	Archivo	Procedimiento o consulta	RF	Rol requerido
login	api.php	sp_login_usuario	RF-08	Público
logout	api.php	session_destroy	RF-09	Sesión
sesion	api.php	$_SESSION	RF-10	Sesión
perfil_obtener, perfil_actualizar	api.php	consulta y UPDATE usuario	RF-11	Cliente
cambiar_password	api.php	UPDATE usuario	RF-12	Cliente
agregar_carrito	api.php	sp_agregar_al_carrito	RF-14	Cliente
ver_carrito	api.php	consulta sobre CARRITO	RF-15	Cliente
actualizar_carrito	api.php	UPDATE detalle_pedido	RF-16	Cliente
vaciar_carrito	api.php	DELETE detalle_pedido	RF-17	Cliente
confirmar_pedido	api.php	transacción (RF-18)	RF-18, RF-19, RF-25, RF-26	Cliente
cancelar_pedido	api.php	transacción	RF-20	Cliente
pedidos_usuario	api.php	consulta sobre pedido	RF-21	Cliente
detalle_pedido	api.php	consulta sobre detalle_pedido	RF-22	Cliente o Admin
saldo_digital	api.php	usuario.saldo_digital	RF-23	Cliente
recargar_saldo	api.php	moverSaldo (RECARGA)	RF-24, RF-30	Cliente o Admin
movimientos_saldo	api.php	transaccion_digital	RF-28	Cliente
obtener_comprobante	api.php	comprobante	RF-29	Cliente o Admin
admin_productos	api.php	sp_admin_listar_productos	RF-38	Admin
crear_producto	api.php	sp_crear_producto	RF-31	Admin
actualizar_producto	api.php	sp_actualizar_producto	RF-32	Admin
actualizar_stock	api.php	sp_actualizar_stock	RF-33	Admin
eliminar_producto	api.php	sp_eliminar_producto	RF-34	Admin

Acción (action)	Archivo	Procedimiento o consulta	RF	Rol requerido
crear_categoria, actualizar_categoria, eliminar_categoria	api.php	sp_*_categoria	RF-35	Admin
subir_imagen	api.php	almacenamiento en img/uploads	RF-36	Admin
restaurar, listar_eliminados	api.php	UPDATE activo / activa	RF-37	Admin
admin_pedidos	api.php	consulta sobre pedido	RF-39	Admin
cambiar_estado_pedido	api.php	transacción con $flujo	RF-40, RF-41, RF-27	Admin
listar_usuarios	api.php	consulta sobre usuario	RF-42	Admin
cambiar_rol	api.php	sp_cambiar_rol	RF-43	Admin
admin_actualizar_usuario	api.php	UPDATE usuario	RF-44	Admin
eliminar_usuario	api.php	sp_eliminar_usuario	RF-45	Admin
tienda_admin, guardar_tienda	api.php	INSERT personalizacion_tienda	RF-46	Admin
tipo=pedidos_*	reporte.php	consultas de pedido y detalle	RF-47	Admin
tipo=usuarios_*	reporte.php	consultas de usuario y pedido	RF-48	Admin
tipo=productos_mas_menos_comprados	reporte.php	ranking sobre detalle	RF-49	Admin
(interno)	mailer.php	notificarPedido	RF-50	Sistema

Anexo B. Control de versiones y aprobación

Versión	Fecha	Descripción del cambio	Responsable
1.0	10/11/2026	Primera versión completa del SRS a partir del código y de la base de datos del proyecto.	Equipo de desarrollo

Rol	Nombre	Firma	Fecha
Líder técnico			

Rol	Nombre	Firma	Fecha
Analista de calidad			
Docente revisor			